EXPERIMENT 12

Security Features and Governance in Zoho Creator

A practical plan for protecting data and administering a patient appointment application

241401038

Submitted by	Kaviya S
Register number	241401038
Application	Patient Appointment Scheduling System

PRACTICAL STUDY AND IMPLEMENTATION PLAN

1. Aim and scope

This experiment outlines security, governance, and administration practices for a Patient Appointment Scheduling System in Zoho Creator. It focuses on account protection, user roles, data permissions, safe Deluge scripting, managed connections, controlled changes, and audit review. Patient contact and medical details require careful access control and accountability.

2. Procedure

Step	Planned activity
1. Identify sensitive data	Review patient profiles, appointment records, and department data to identify personal and medical fields.
2. Protect accounts	Plan strong passwords and two-factor sign-in; consider single sign-on where available.
3. Assign roles	Define Administrator, Doctor, Front desk, and Patient roles using least privilege.
4. Set access rules	Check sign-in, role, form/report permission, and record/field criteria.
5. Secure code and connections	Validate inputs and store credentials in managed connections rather than scripts.
6. Govern releases	Use development, staging, approval, production, and audit review steps.

3. Output — layered security

Layer	Purpose
Account and sign-in	Strong passwords, multi-factor sign-in, single sign-on, and session controls.
Application access	Profiles and roles decide which parts of the application are available.
Data access	Form, report, field, and record criteria limit visible and editable information.
Logic and integrations	Validate data, restrict connections, and avoid secrets in source code.
Governance and audit	Manage environments, approvals, audit trails, backups, and regular reviews.

The layers work together as defence in depth: when one safeguard is missed, other controls can still reduce exposure.

3.1 Proposed permission matrix

This is a proposed design; actual profile settings should be verified in the live Creator application.

Area	Admin	Doctor	Front desk	Patient
Patient profile	Full control	Assigned patients	Create/view/edit	Own record
Appointments	Full control	View/update status	Create/view/edit	Own appointments
Departments	Full control	View	View	No access
Medical fields	View/edit	View	Limited/hidden	Own entry
Reports/exports	All reports	Own reports	Daily schedule	No access
Users/connections	Manage	No access	No access	No access

24AD01038

3.2 Access-control decision flow

Check	Pass	Fail
Authentication	Check the user's assigned profile.	Deny access and request sign-in.
Role permissions	Check requested form/report access.	Deny access if permission is missing.
Record and field criteria	Show only permitted records and fields.	Restrict visibility or deny the action.
Audit	Log relevant actions for review.	Review unusual or repeated failures.

3.3 Secure scripting and connections

Validation should reject missing treatment consent and ages outside the expected range before a patient profile is submitted. For example, the supplied experiment uses a Deluge validation pattern that displays an alert and cancels submission when consent is not confirmed. A separate check rejects age values below 0 or above 120.

When connecting to Zoho Calendar or another service, use a named managed connection and avoid writing credentials into code. Keep configurable identifiers in settings when practical. Code examples are illustrative and need testing.

3.4 Change lifecycle

Develop	Test	Approve	Publish	Monitor
Build in development.	Test in staging.	Review changes and access.	Release to production.	Check audit trail and errors.

3.5 Risks and controls

Risk	Example	Control
Unauthorised access	Former staff can view patient data.	Remove access promptly and use sign-in safeguards.
Excess privilege	Staff can delete or export too many records.	Apply least privilege and separate permissions.
Data leakage	A sensitive report is shared publicly.	Review sharing settings and avoid public links.
Insecure scripts	Missing validation or embedded secrets.	Validate inputs, use connections, review code.
Uncontrolled release	A live change breaks booking.	Test in staging and approve before release.
Poor traceability	A change cannot be traced.	Review audit trails and logs.

3.6 Administration checklist

Area	Routine task	Frequency
Users	Assign profiles correctly; remove leavers.	On change
Permissions	Review profiles and export rights.	Quarterly
Sign-in	Check multi-factor or SSO settings.	Quarterly
Connections	Restrict connections to required users/apps.	Quarterly
Changes	Test in staging before publication.	Every release
Audit and recovery	Review unusual activity and test backup readiness.	Monthly/as planned

4. Final result

A proposed security and governance plan was prepared covering sign-in, role-based access, record permissions, safe scripting, managed connections, staged changes, audit review, and administration routines. The original material describes these as planned settings rather than proof that every option was enabled, so the live configuration should be verified before use.

24140138